

A PRACTICAL ENGINEERING HANDBOOK & WORKBOOK

HIPAA for *Medical* *Application* Developers

*Turning the law into trust boundaries, data
contracts, negative tests, and evidence.*

ARCHITECTURE

CODE

EVIDENCE

INTEGRATIONS

DELIVERY

Anthony Narine

DEVELOPER LEARNING EDITION • SEPTEMBER 2026

HIPAA for Medical Application Developers

Copyright © 2026 Anthony Narine. All rights reserved.

Free developer learning edition, published at anthonymarine.com/hipaa.

This book is an educational engineering handbook. It is not legal advice, a compliance certification, or a substitute for counsel, a privacy officer, a security officer, or organization-specific policy. HIPAA obligations depend on role, data flow, contracts, purpose, and facts. The HIPAA regulations and official HHS guidance control if this book conflicts with them.

Regulatory status used in this edition (checked September 2026): the existing HIPAA Security Rule remains the rule currently in effect. HHS announced a proposed rule in December 2024 to strengthen cybersecurity requirements (published January 6, 2025). As of this edition it has not been finalized; a proposed rule is not a final rule. The 2024 amendments to 42 CFR Part 2 (substance use disorder records) required compliance by February 16, 2026. Re-check HHS and eCFR before making production or contractual decisions.

THE ENGINEERING PROMISE OF THIS BOOK

By the end, you should be able to look at a medical application and answer five questions: What regulated data exists? Where does it move? Who is allowed to act on it? What can go wrong? What evidence proves the control actually works?

Contents

–	How to use this handbook	5
I	<i>Understand the law before the code</i>	
01	What HIPAA is — and is not	10
02	Covered entities, business associates, and the BAA perimeter	12
03	PHI, ePHI, identifiers, and context	14
04	Privacy Rule vs Security Rule vs Breach Notification Rule	17
05	How to read HIPAA like an engineer	19
II	<i>Control the data</i>	
06	Minimum necessary as API and query design	22
07	De-identification: the boundary where PHI can stop being PHI	26
08	Safe Harbor in practice	28
09	Expert Determination and the Limited Data Set	32
10	Free text, analytics, research, and AI model boundaries	34
11	Patient rights and the designated record set	37
III	<i>Build the Security Rule into architecture</i>	
12	Risk analysis and risk management	42
13	Administrative and physical safeguards developers still need to understand	44
14	Access control and emergency access	46
15	Authentication, sessions, and identity proof	49
16	Audit controls: security telemetry vs ePHI activity	51
17	Integrity and clinical meaning	56
18	Transmission security and encryption decisions	58
19	Availability, backups, and downtime	60
20	Documentation, evidence, retention, and review	62
IV	<i>Clinical systems and cloud boundaries</i>	
21	HL7, MLLP, TCP, and interface security	67
22	DICOM and medical image security	69

23	Cloud vendors, BAAs, secrets, and object storage	71
24	Multi-tenancy, facilities, support access, and break-glass	74
V <i>Secure software engineering</i>		
25	OWASP Top 10:2025 for medical applications	77
26	OWASP ASVS 5.0 as a verification backbone	80
27	Threat modeling and secure design	82
28	Secure development lifecycle and supply-chain assurance	84
29	Testing controls, exceptional conditions, and fail-safe behavior	86
30	Incident response, breach readiness, and evidence preservation	88
VI <i>Capstone</i>		
31	Perform a HIPAA engineering review of Lumen — then your own system	93
 <i>Reference</i>		
A	Quick reference: HIPAA developer questions	99
B	OWASP Top 10:2025 checklist	101
C	Vocabulary for medical application developers	103
D	Stack translation: Django, FastAPI, Next.js, Convex, Clerk	105
–	Reference map	109
–	Final self-assessment	111

How to use this handbook

This is not a glossary with code sprinkled on top. It is a build-and-review method. HIPAA tells regulated organizations what outcomes must be achieved. Your job as a developer is to translate those outcomes into trust boundaries, data contracts, authorization decisions, durable evidence, recovery behavior, vendor boundaries, and tests.

The three systems in this book

Every example comes from software I designed and built, so the tradeoffs are real rather than hypothetical. You will see each name again in the shaded case-study notes throughout the chapters.

Lumen

PRIMARY CASE
STUDY

A clinical reporting platform for vascular ultrasound, designed to carry a study from the order that arrives out of the EHR, through the exam, measurements, and interpretation, to the signed final report. Patient identity, conclusions, PDFs, images, HL7 interfaces, multi-tenant organizations and facilities, cloud storage, and AI-assisted workflows make every hard part of HIPAA concrete. Lumen is pre-production: it runs on synthetic data and has not yet handled real patient ePHI.

Gait

IDENTITY &
SECURITY

A security platform built around authentication, two-factor sign-in, session control, audit evidence, and constrained AI security agents that propose repairs a human must approve. It supplies the identity, session, and secure-delivery examples.

EstateIQ

BOUNDARY
EXAMPLE

A financial SaaS for small landlords: properties, leases, tenants, and rent ledgers. It is not a healthcare product, and that is exactly why it appears. It shows that sensitive private data is not automatically PHI.

Reading the case-study labels

A book that asks you to separate claims from evidence should do the same with its own examples. Every Lumen note carries one of four labels, and the table below records Lumen’s state as of this edition.

IMPLEMENTED	Built and tested in the codebase (on synthetic data).
PARTIAL	Built, with a known and tracked gap before production use.
PLANNED	Designed and on the roadmap, not built.
ILLUSTRATIVE	A scenario or pattern used for teaching; not a claim about Lumen’s code.

LUMEN CAPABILITY	STATUS	NOTE
Tenant / facility isolation	Implemented	Org-scoped selectors, membership permission, Postgres row-level security backstop, cross-tenant adversarial test matrix.
Workflow audit trail	Implemented	Append-only history for sign, finalize, unfinalize, addendum, export.
Finalize lock + addenda	Implemented	Post-signature change requires a logged addendum.
Inbound HL7 orders (ADT / ORM over MLLP)	Partial	Listener and order intake built; TLS/MLLPS and sender authentication open.
Outbound results (ORU) to the EHR	Planned	Next integration phase.

Media storage (object store)	Partial	Private, UUID-keyed objects; media access audit open.
DICOM networking	Illustrative	Used in Chapter 22 as a pattern.
ePHI read-access log	Planned	The largest open control; see Chapter 16.
AI criteria assistant	Partial	Authenticated and org-scoped; vendor BAA and input restrictions open.
Backups, restore tests, break-glass	Planned	Required before real ePHI.

That gap list is deliberate teaching material. A system can have excellent tenant isolation and still be unready for real patients. The Capstone asks you to produce exactly this kind of honest table for your own system.

The stack in this book

Most code examples use Django and Django REST Framework because Lumen does. The controls themselves are stack-neutral. Appendix D translates each enforcement point into FastAPI, Next.js/React, Convex, and Clerk, including the traps specific to each: public serverless functions, server actions, client-bound props, read-only queries that cannot write audit rows, and user-writable identity metadata.

RECURRING ENGINEERING LOOP

RULE → DEVELOPER QUESTION → ARCHITECTURE → CODE ENFORCEMENT POINT →
NEGATIVE TEST → EVIDENCE → GAP / RESIDUAL RISK

What this book covers

- **HIPAA foundations:** Privacy, Security, Breach Notification, HITECH, covered entities, business associates, PHI and ePHI.
- **Data-use engineering:** minimum necessary, de-identification, Safe Harbor, Expert Determination, limited data sets, DUAs, AI boundaries.
- **Security Rule implementation:** risk analysis, access control, audit controls, integrity, authentication, transmission security, availability,

- vendors and documentation.
- **Medical integrations:** HL7, MLLP, TCP, DICOM, object storage, cloud services, clinical workflow integrity and downtime behavior.
- **Modern application security:** OWASP Top 10:2025, OWASP ASVS 5.0, threat modeling, secure SDLC, supply chain, error handling, testing and incident response.

Primary sources for this edition include 45 CFR Parts 160 and 164, HHS/OCR HIPAA guidance, and official OWASP Top 10:2025 / ASVS 5.0 materials. See the Reference Map.

PART

I

Understand the law before the code

-
- 01 What HIPAA is — and is not
 - 02 Covered entities, business associates, and the BAA perimeter
 - 03 PHI, ePHI, identifiers, and context
 - 04 Privacy Rule vs Security Rule vs Breach Notification Rule
 - 05 How to read HIPAA like an engineer
-

What HIPAA Is — and Is Not

LEARNING OBJECTIVE

Explain the role of HIPAA in a medical application without treating “HIPAA compliant” as a magic product property.

HIPAA is a federal legal framework, not a software framework. For developers, the most useful mental model is that HIPAA creates obligations around information, organizations, people, contracts, processes, and evidence. Code is one mechanism used to satisfy some of those obligations. A perfect access-control function cannot replace workforce training, a missing business associate agreement, or an incident-response process. Likewise, good policies cannot compensate for an API that lets one tenant enumerate another tenant’s exams.

Three rules you must keep separate

- **Privacy Rule:** governs many uses and disclosures of PHI and gives individuals rights concerning their information.
- **Security Rule:** protects ePHI through administrative, physical, and technical safeguards.
- **Breach Notification Rule:** governs notification after certain impermissible uses or disclosures that compromise PHI, subject to the rule’s definitions and risk-assessment framework.

HITECH strengthened HIPAA, including direct Security Rule obligations for business associates and expanded enforcement. Your architecture therefore sits inside a legal and organizational system; it is not the whole system.

CAUTION

Do not make this claim lightly

“HIPAA compliant” is not equivalent to “encrypted,” “hosted on AWS,” “uses a BAA,” “passed a penetration test,” or “uses a healthcare model.” Compliance is a system-of-controls conclusion that depends on the regulated entity’s full facts.

RULE	45 CFR Part 164
DEVELOPER QUESTION	Which HIPAA rule applies to this data flow and actor?
ARCHITECTURE ANSWER	Data classification + role/contract map + security/privacy controls.
EVIDENCE	Current diagrams, contracts, policies, tests, audit evidence.

MASTERY CHECK

01 Why can a technically secure product still fail HIPAA?

02 Why can a product outside HIPAA still deserve strong privacy and security controls?

Covered Entities, Business Associates, and the BAA Perimeter

LEARNING OBJECTIVE

Determine who is regulated in a software relationship and why contracts and data flow change architecture decisions.

The Security Rule applies to covered entities and business associates. A software vendor can become a business associate when it creates, receives, maintains, or transmits PHI on behalf of a covered entity for a regulated service. The same vendor can have one HIPAA-regulated customer deployment and another workflow that is outside HIPAA. Start with the relationship and purpose, not the file extension.

A developer-facing boundary test

1. Identify the customer and its HIPAA role.
2. Identify what information your service creates, receives, maintains, or transmits for that customer.
3. Identify every subcontractor that can receive or maintain that information.
4. Identify which services are included in contractual assurances such as BAAs.
5. Draw the “BAA perimeter”: which systems and vendors are approved to handle PHI for this workflow?

A BAA does not make unsafe code safe. It establishes contractual duties and permitted handling. Conversely, a strong technical stack does not remove the need for a BAA when one is required.

LUMEN VASCULAR REPORTING PLATFORM

ILLUSTRATIVE

Where the regulated data flow really ends

If Lumen stores patient identifiers, vascular measurements, images, and reports for a hospital, the deployment is plainly handling PHI/ePHI. If an external error-tracking service receives report payloads, that service has crossed into the regulated data flow whether or not the developer intended it.

EXERCISE

Draw your BAA perimeter

Draw Lumen, its database, media storage, identity provider, logging provider, AI provider, email/SMS services, and hospital interface engine. Mark which components can receive PHI and which contractual boundary covers each one.

PHI, ePHI, Identifiers, and Context

LEARNING OBJECTIVE

Classify information correctly and explain why identifiers become regulated through context and linkage.

PHI is not synonymous with “medical-looking data.” HIPAA protects individually identifiable health information in covered contexts. ePHI is the electronic subset protected by the Security Rule. A blood-flow velocity with no person or context may be ordinary scientific data; the same value tied to a patient encounter is part of a health record.

Think in data classes, not database tables

- **Direct identifiers:** name, MRN, email, phone, account identifiers and similar direct links.
- **Clinical content:** diagnoses, measurements, conclusions, imaging, medications, procedures, notes.
- **Operational metadata:** timestamps, facility, clinician, device, interface destination, request identifiers.
- **Security metadata:** subject IDs, IP addresses, session IDs, denied actions, authentication events.
- **Derived data:** scores, model embeddings, labels, summaries, feature vectors, and analytics outputs.

Do not assume derived data is outside HIPAA merely because the original name is absent. If the data can still be linked to an individual in the regulated context, it may remain PHI.

SCOPE CHECKPOINT

Special data classes carry extra rules

HIPAA is a floor, not the whole map. Some records carry additional or stricter requirements, and a developer's job is to **identify them and route the decision to a specialist**, not to become a second regulatory handbook:

- **42 CFR Part 2:** substance use disorder treatment records from federally assisted programs. Consent, redisclosure, and labeling rules differ from HIPAA; the 2024 amendments required compliance by February 16, 2026.
- **Psychotherapy notes:** a narrowly defined category with stricter authorization requirements under the Privacy Rule.
- **State law:** stricter rules for mental health, HIV, genetic, reproductive, and minors' records, and state breach-notification deadlines that can be shorter than HIPAA's.
- **Outside HIPAA entirely:** consumer health apps that are not covered entities or business associates may fall under the FTC Health Breach Notification Rule instead.
- **Information blocking:** certain actors, including developers of certified health IT, have separate obligations not to unreasonably interfere with access, exchange, or use of electronic health information.

Engineering control: tag special classes at ingestion (a data-class field, not a comment), make them filterable in exports and AI paths, and add a design-review question: "Could this workflow touch a special data class?"

ESTATEIQ LANDLORD FINANCE SOFTWARE • NOT HEALTHCARE**Sensitive is not the same as PHI**

A landlord's tenant name and rent ledger are private data, but they are not PHI merely because they are sensitive. HIPAA is relationship- and purpose-dependent.

MASTERY CHECK

01 Give one example of data that looks harmless until it is linked to an encounter.

02 What is the difference between PHI and ePHI for Security Rule scope?

Privacy Rule vs Security Rule vs Breach Notification Rule

LEARNING OBJECTIVE *Separate data-use permission, security safeguards, and breach response so architecture discussions do not collapse three different problems into one.*

A useful engineering shorthand is: the Privacy Rule asks when PHI may be used or disclosed; the Security Rule asks how ePHI must be protected; the Breach Notification Rule asks what happens after certain impermissible uses or disclosures. This is simplified, but it prevents a common design failure: treating security controls as permission to use data for any purpose.

PRIVACY QUESTION	<i>May this PHI be used or disclosed for this purpose?</i>
SECURITY QUESTION	<i>How is the ePHI protected while stored, used, and transmitted?</i>
BREACH QUESTION	<i>What facts must be preserved and evaluated after an incident?</i>

The rules interact. Minimum necessary under the Privacy Rule influences access-management decisions under the Security Rule. Audit evidence generated for security can become critical during breach analysis. De-identification can remove information from PHI status under the Privacy Rule when the regulatory standard is actually met.

EXERCISE

Classify the question

For each, write Privacy, Security, Breach, or More Than One: “Can we send this report to an AI vendor?”, “How do we encrypt the connection?”, “Who saw the record after a compromised account?”, “Can research receive exact dates?”

How to Read HIPAA Like an Engineer

LEARNING OBJECTIVE

Turn a regulation into a question your architecture, code, operations, and evidence must answer.

HIPAA is deliberately technology-neutral. That vagueness is not an excuse to stop at policy language. Read each requirement as a design question. When §164.312(b) calls for mechanisms to record and examine activity in systems that contain or use ePHI, the engineering question is not “do we have logs?” It is “which actions are recorded, where, with what fields, who can alter them, how are they reviewed, and what proves that coverage is complete?”

The seven-step translation

1. Read the standard and identify whether an implementation specification is required or addressable.
2. State the security or privacy outcome in plain language.
3. Write the developer question the system must answer.
4. Name the trust boundary and enforcement point.
5. Define the negative test: how would you prove the control cannot be bypassed?
6. Define the evidence artifact.
7. Record residual risk, owner, and review date.

KEY DISTINCTION

Addressable does not mean optional

Under the current Security Rule, an addressable implementation specification requires a reasoned determination. Implement it when reasonable and appropriate; use an equivalent alternative when appropriate; or document why the specification is not reasonable and appropriate in the circumstances and how the standard is otherwise met.

RULE	§164.312(e) Transmission security
DEVELOPER QUESTION	Can unauthorized parties read or modify ePHI in transit?
ARCHITECTURE ANSWER	TLS/VPN/private connectivity + peer authentication + destination binding + authorization.
EVIDENCE	Configuration, certificate/route records, tests, monitoring, interface inventory.

MASTERY CHECK

- 01

Why is “we use AES-256” not an answer to an entire HIPAA safeguard?
- 02

What is the difference between a control and evidence of a control?

PART

II

Control the data

-
- 06 Minimum necessary as API and query design
 - 07 De-identification: the boundary where PHI can stop being PHI
 - 08 Safe Harbor in practice
 - 09 Expert Determination and the Limited Data Set
 - 10 Free text, analytics, research, and AI model boundaries
 - 11 Patient rights and the designated record set
-

Minimum Necessary as API and Query Design

LEARNING OBJECTIVE

Express the Privacy Rule minimum-necessary principle as row scope, field projection, purpose, and data-contract design.

The minimum necessary standard generally requires reasonable steps to limit many uses, disclosures, and requests for PHI to what is needed for the intended purpose. For developers, this is not abstract ethics. It changes selectors, serializers, GraphQL/Convex queries, REST response contracts, exports, background jobs, and model prompts.

Authorization and minimum necessary are related but different

Authorization asks whether the principal may access the resource. Minimum necessary also asks how much of that resource and which fields are needed for the purpose. A clinician may be authorized to access an encounter and still not need every internal note or administrative field for a summary list.

Where the standard does not apply

The word “generally” matters. Under §164.502(b)(2), the minimum necessary standard does not apply to:

EXCEPTION

WHAT IT MEANS FOR YOUR PRODUCT

Disclosures to, or requests by, a health care provider for treatment	A referring physician receiving a vascular report does not need a field-trimmed version for legal reasons. Clinical completeness wins.
Uses or disclosures to the individual	A patient's access to their own record is governed by the right of access (Chapter 11), not by minimization.
Uses or disclosures under a valid authorization	Scope is set by the authorization's terms.
Disclosures to HHS for compliance and enforcement	Your evidence and export tooling may be used here.
Uses or disclosures required by law	Limited to what the law requires.
Uses or disclosures required for HIPAA compliance	For example, data needed to meet other rule requirements.

KEY DISTINCTION

The legal exception is not an engineering exception

The treatment exception removes a legal requirement to minimize; it does not make over-broad APIs a good idea. Server-side field projection still reduces breach blast radius, browser exposure, log leakage, and cache risk. Keep the engineering discipline everywhere, and use the legal map to decide where a *complete* record must remain reachable — for treatment and for the patient.

The standard applies to business associates too: a BAA typically requires the vendor to limit its own uses, disclosures, and requests to the minimum necessary. For routine, recurring disclosures, the regulated entity can set standard protocols once; that is exactly what a well-designed response contract encodes.

```
# Bad shape: broad row set + broad serializer
Exam.objects.filter(organization=org)
# response includes patient, report body, internal notes, image metadata...

# Better shape: scope rows, then project the contract
ExamSelector.for_actor(actor, org, facility).values(
    'id', 'exam_type', 'exam_date', 'status'
)[:50]
```

The same decision in other stacks — scope first, then project a named contract:

```
# FastAPI: response_model filters output to the contract's fields
@router.get("/exams", response_model=List[ExamSummary])
def list_exams(ctx: OrgContext = Depends(require_org_member)):
    return exam_selector.for_actor(ctx).limit(50)

// Convex: authorize inside the function, return a projection
export const listExams = query({ args: {}, handler: async (ctx) => {
    const m = await requireMembership(ctx); // throws if absent
    const rows = await ctx.db.query("exams")
        .withIndex("by_org", q => q.eq("orgId", m.orgId)).take(50);
    return rows.map(({ _id, examType, examDate, status }) =>
        ({ _id, examType, examDate, status }));
}});
```

Four questions for every endpoint

- **Rows:** which records does this actor need?
- **Fields:** which attributes does this UI or process actually render/use?
- **Purpose:** what workflow justifies the access?
- **Retention/copying:** does the consumer keep, cache, export, log, or forward the data?

COMMON MISTAKE

Client filtering is not minimization

If the server sends the full PHI object and React hides three fields, those fields were still disclosed to the browser. The server-side query/selector and serializer contract must enforce the decision.

EXERCISE

Shrink the payload

Take an exam-list API that returns the full patient and report. Design a summary contract for the worklist and a separate detail contract for authorized report review.

De-identification: The Boundary Where PHI Can Stop Being PHI

LEARNING OBJECTIVE

Explain why de-identification is powerful, strict, and different from pseudonymization or “removing names.”

Under the HIPAA Privacy Rule, health information that is de-identified in accordance with §164.514 is not individually identifiable health information and therefore is not PHI under the Privacy Rule. That is a major boundary change. But it does not mean the data is free of every possible obligation: contracts, research rules, state law, ethical commitments, intellectual-property restrictions, or other privacy regimes can still matter.

HIPAA provides two methods

- **Safe Harbor:** remove the specified identifier categories and have no actual knowledge that the remaining information could identify the individual.
- **Expert Determination:** a qualified expert applies accepted statistical/scientific methods, determines that identification risk is very small in the anticipated context, and documents the methods and results.

COMMON MISTAKE

Pseudonymized is not automatically de-identified

Replacing MRN 12345 with patient_8fd2 does not by itself satisfy Safe Harbor or Expert Determination. A stable code can still permit linkage and can remain PHI depending on how it is created and used.

For medical AI, de-identification is often discussed as a way to reduce exposure outside a HIPAA-regulated relationship. The engineering mistake is to invent a “de-identified” flag without implementing one of the regulatory methods and without testing the transformation boundary.

MASTERY CHECK

01 Why is “remove the patient name” not a de-identification method?

02 What changes legally when data is properly de-identified under the HIPAA Privacy Rule?

Safe Harbor in Practice

LEARNING OBJECTIVE

Implement and test the Safe Harbor method without accidentally retaining dates, location detail, or rare identifying context.

Safe Harbor is mechanical enough to be engineered, but only if the team understands the full rule. The method requires removal of 18 identifier categories for the individual and for relatives, employers, or household members, plus no actual knowledge that the remaining information could identify the individual.

The 18 categories — developer checklist

1. Names.
2. Geographic subdivisions smaller than a state, subject to the special three-digit ZIP rule.
3. All elements of dates directly related to an individual, except year, with special treatment for ages over 89.
4. Telephone numbers.
5. Fax numbers.
6. Email addresses.
7. Social Security numbers.
8. Medical record numbers.
9. Health plan beneficiary numbers.
10. Account numbers.

11. Certificate/license numbers.
12. Vehicle identifiers and serial numbers, including plates.
13. Device identifiers and serial numbers.
14. Web URLs.
15. IP addresses.
16. Biometric identifiers such as finger and voice prints.
17. Full-face photographs and comparable images.
18. Any other unique identifying number, characteristic, or code, subject to the rule's provisions.

Dates, age, and ZIP are where implementations break

Safe Harbor removes date elements more specific than year when the dates are directly related to an individual. Ages over 89 and date elements that indicate such age must be aggregated into a category of age 90 or older. The initial three digits of a ZIP code can be retained only when the geographic unit formed by combining all ZIP codes with those same three digits contains **more than 20,000 people**, according to current publicly available Census data; otherwise the three digits are replaced with 000. The restricted-prefix list is data, not code: version it, cite its Census source, and review it when new Census data is published.

The function below is **illustrative only**. It shows the shape of a transformation boundary for a few structured fields; it does not, by itself, establish that anything is de-identified.

```
# ILLUSTRATIVE – one piece of a Safe Harbor pipeline, not the pipeline
def to_safe_harbor(encounter):
    return {
        'visit_year': encounter.visit_date.year,
        'age_band': ('90+' if encounter.age > 89
                     else band(encounter.age)),
        'zip3': allowed_zip3(encounter.zip) or '000',
        'icd10': [d.code for d in encounter.diagnoses],
        # no narrative note crosses this boundary
    }
```

What that function does not do

- **Every field, not a few:** Safe Harbor applies to the whole released dataset. Any other column, file, or join key that carries one of the 18 identifiers defeats the method.
- **Metadata:** file names, object keys, DICOM headers, PDF properties, burned-in image text, spreadsheet tab names, and export timestamps can all carry identifiers.
- **Relatives, employers, household members:** their identifiers must be removed too.
- **Actual knowledge:** if the releasing organization knows the remaining data could identify someone, Safe Harbor is not met. A rare ICD-10 code, an unusual procedure at a small facility, or a combination of year, zip3, and diagnosis can do that in a particular dataset. That knowledge lives with people and the recipient context, not in the function.
- **Re-identification codes:** any retained code must not be derived from identifiers and must not be disclosed with its key.

PRINCIPLE

A function is not a determination

De-identification is a documented decision about a dataset and a release, owned by a named person, supported by the transformation code, the full field inventory, the adversarial tests, and the actual-knowledge review. Record all five as evidence. If utility requires keeping more detail, that is a signal for Expert Determination (Chapter 9), not for loosening the code.

TEST DESIGN

Test the 94-year-old

A de-identification test suite should contain adversarial fixtures: age 94, a restricted ZIP prefix, multiple direct identifiers, URLs/IPs, device serials, and narrative text. The test should assert what is absent, not merely what is present.

EXERCISE

Safe Harbor test matrix

Create five records designed to defeat a naive scrubber. Include a 94-year-old, rare condition, exact procedure date, restricted ZIP prefix, and device serial number. Write expected transformed output.

Expert Determination and the Limited Data Set

LEARNING OBJECTIVE

Choose between Safe Harbor, Expert Determination, a limited data set, or keeping PHI inside the regulated perimeter.

Expert Determination

Expert Determination is not a developer self-certification. A person with appropriate knowledge and experience in accepted statistical and scientific principles determines that the risk is very small that the anticipated recipient could identify an individual using the data alone or with other reasonably available information, and the methods and results are documented. It can preserve data utility that Safe Harbor would destroy, such as more precise temporal information, when the expert's analysis supports it.

Limited Data Set

A limited data set under §164.514(e) is still PHI. It excludes specified direct identifiers but can retain information such as dates and certain geography. It may be used or disclosed for research, public health, or health care operations when the regulatory conditions are met, including a Data Use Agreement.

KEY DISTINCTION

Do not collapse these states

Identified PHI ≠ Limited Data Set ≠ De-identified data. A limited data set remains PHI. De-identified data under §164.514(a)–(b) is not PHI under the Privacy Rule.

NEED	IDENTIFIED PHI	LIMITED DATA SET	DE-IDENTIFIED
Exact dates for care	Often yes	Not the usual care path	May remove too much
Research with dates/site geography	Possible with appropriate basis	Often useful + DUA	Expert method may preserve more
Public dataset	No	No	Potentially, subject to other law/contract
Model vendor without HIPAA arrangement	High-risk decision	Still PHI	Possible if truly de-identified

MASTERY CHECK

01 Why is a limited data set still PHI?

02 When could Expert Determination be preferable to Safe Harbor?

Free Text, Analytics, Research, and AI Model Boundaries

**LEARNING
OBJECTIVE**

Design outbound data paths so narrative text, derived data, prompts, and model telemetry do not silently escape the intended privacy boundary.

Structured fields are easier to transform because the schema tells you where identifiers live. Free text is different. Notes can contain names, exact dates, ages, providers, employers, family relationships, facilities, rare conditions, addresses, and narrative clues. Regex can remove obvious patterns and still miss the identifying context that matters.

Three safe design postures

1. Do not collect or transmit narrative text when the feature does not need it.
2. Keep identified text inside the approved PHI/BAA perimeter and apply minimum necessary, authorization, retention, and audit controls.
3. Use a validated de-identification process appropriate to the regulatory method and validate its performance, including human review where warranted.

AI boundary record

PURPOSE

Why does the model need this information?

DATA CLASS	PHI, limited data set, or de-identified?
PROVIDER	BAA/contract coverage and service scope.
RELATIONSHIP	
TRAINING / RETENTION	What happens to prompts, outputs, abuse logs, and telemetry?
MINIMUM NECESSARY	What fields/text are actually required?
OUTPUT HANDLING	Can the output itself contain PHI or become part of the designated record set?
HUMAN REVIEW & FAILURE	What happens when the model is wrong or unavailable?

LUMEN VASCULAR REPORTING PLATFORM

PARTIAL

Removing the header name is not enough

A vascular report sent to an AI assistant may contain patient identifiers in headers and identifying details in narrative text. Removing the header name is not enough. Decide first whether the provider may receive PHI. If not, use a real de-identification strategy rather than a cosmetic scrubber. In Lumen today, the criteria assistant is authenticated and organization-scoped, but the vendor agreement and a user-facing “no identifiers” input rule are still open. It is cleared for synthetic data only until both close.

EXERCISE

AI data-flow review

For a “discuss this vascular protocol/report” feature, document purpose, input fields, de-identification state, model vendor, retention, logging, output destination, authorization, and failure behavior.

Patient Rights and the Designated Record Set

LEARNING OBJECTIVE

Build the product capabilities a covered entity needs to honor access, amendment, and accounting requests — including for records a vendor holds.

The Privacy Rule gives individuals rights over their information. The covered entity owns the obligation to respond, but when a vendor maintains the records, the vendor's product is often where the answer lives. A BAA generally requires the business associate to make PHI available for access, to make amendments, and to provide the information needed for an accounting of disclosures. If your system cannot find and export one patient's records quickly, your customer cannot meet its deadline.

The designated record set

The designated record set (§164.501) is the group of records used, in whole or in part, to make decisions about individuals: for a provider, the medical and billing records, and for a health plan, enrollment, payment, claims, and case-management records. Information a business associate maintains for the covered entity can fall inside it. For a reporting platform, think: signed reports, addenda, measurements and conclusions that support them, images used for interpretation, and the PDFs sent to the chart.

Usually outside it: security logs, internal quality-assurance data not used for decisions about the individual, and system telemetry. The line is a decision for the covered entity; your job is to make each data class *labelable* so the decision can be applied in code.

Three rights, three capabilities

RIGHT	RULE AND CLOCK	PRODUCT CAPABILITY
Access	\$164.524. Act within 30 days; one 30-day extension with written notice.	Locate every DRS record for a patient across services and export it in the electronic form and format requested when readily producible, or an agreed alternative. Support sending to a third party the patient designates.
Amendment	\$164.526. Act within 60 days; one 30-day extension.	Append or link an amendment to the affected records — never silently overwrite. Record accepted and denied requests, the patient's statement of disagreement, and who was notified.
Accounting of disclosures	\$164.528. Six-year lookback; act within 60 days; one 30-day extension.	A disclosure log recording date, recipient, description, and purpose for accountable disclosures. Treatment, payment, operations, disclosures to the patient, and disclosures under authorization are among the exclusions.

KEY DISTINCTION

Access log ≠ disclosure log

An ePHI access log (Chapter 16) records internal activity for security. A disclosure log records information leaving the covered entity for accountable purposes, such as a public-health report or a response to a court order. Sending a signed report to the ordering physician's EHR is a treatment disclosure and generally not accountable. Build the disclosure log as its own event type with a purpose field, so the covered entity's privacy officer can filter to what is accountable.

Engineering the patient export

- 1. **Patient resolution:** given an identity (MRN plus organization), find the patient across every service — including merged or corrected identities.
- 2. **Record discovery:** each service registers which of its data classes belong to the DRS. Discovery queries the registry, not a hand-maintained list.
- 3. **Assembly:** reports and addenda as PDF, structured data in a documented machine-readable format, images in their native format or an agreed rendering.
- 4. **Scope:** exports run under a named privileged role, tenant-scoped, and audited as a disclosure when the recipient is outside the covered entity.
- 5. **Delivery:** through the covered entity’s channel, unless the BAA says the vendor responds directly.

LUMEN

VASCULAR REPORTING PLATFORM

PARTIAL

Amendment already has a shape

Lumen’s finalize lock and logged addenda are the right foundation for §164.526: a signed report is never overwritten, and every change after signature is a new, attributable record. The missing pieces are a patient-level export and a disclosure log with a purpose field. Both are needed before a hospital customer could meet an access request against Lumen-held records.

RULE	§164.524 Right of access
DEVELOPER QUESTION	Can we produce every DRS record for one patient, correctly scoped, well within 30 days?
ARCHITECTURE ANSWER	DRS registry per service + patient resolver + export job + disclosure event.

NEGATIVE TEST	A fixture patient with records in every service, a merged identity, and an addendum: the export must contain all of them and nothing from another patient or tenant.
EVIDENCE	Export completeness test, runbook, timed dry run, sample export.

EXERCISE

Design the patient export

List every data class your system holds for one patient. Mark each as in the designated record set, outside it, or “ask the covered entity.” Then write the completeness test.

PART

III

Build the Security Rule into architecture

-
- 12 Risk analysis and risk management
 - 13 Administrative and physical safeguards developers still need to understand
 - 14 Access control and emergency access
 - 15 Authentication, sessions, and identity proof
 - 16 Audit controls: security telemetry vs ePHI activity
 - 17 Integrity and clinical meaning
 - 18 Transmission security and encryption decisions
 - 19 Availability, backups, and downtime
 - 20 Documentation, evidence, retention, and review
-

Risk Analysis and Risk Management

**LEARNING
OBJECTIVE**

Build a defensible risk register tied to real ePHI assets, threats, vulnerabilities, controls, owners, dates, and evidence.

The Security Rule's risk-analysis requirement is not a vulnerability scan. A scan can find technical weaknesses, but it cannot discover every workflow, vendor dependency, support process, clinical failure mode, or human action. Risk analysis is a system model: what ePHI exists, where it is, what can threaten it, what weaknesses make harm plausible, and what controls reduce the risk.

Write risk scenarios, not nouns

"SQL injection" is a weakness category. A risk scenario is more useful: "An unauthenticated attacker injects a crafted filter value into the report-search path, causing the database to return ePHI from multiple organizations." The scenario identifies actor, action, vulnerable boundary, asset, and consequence.

RISK	Cross-tenant exam disclosure
ASSET	Patient exam + report
THREAT	Authenticated user changes exam identifier
VULNERABILITY	Object lookup not tenant-scoped
CONTROL	Centralized selector + permission + object ownership check

EVIDENCE	Negative API test returns 404/403 and audit event
OWNER	Reports team
REVIEW	Quarterly / material architecture change

EXERCISE

Top ten risks

Write the ten most credible ePHI risk scenarios for your application. Include at least one confidentiality, integrity, availability, insider, vendor, and recovery scenario.

Administrative and Physical Safeguards Developers Still Need to Understand

LEARNING
OBJECTIVE

Recognize the non-code safeguards that change product requirements and operational design.

Developers often jump directly to §164.312 technical safeguards and miss that the Security Rule also requires administrative and physical safeguards. These requirements create product constraints: workforce authorization changes require timely access changes; incident procedures require usable logs; contingency planning requires recoverable systems; device/media controls affect local downloads and removable media; facility/workstation safeguards affect kiosk and shared-workstation behavior.

Developer touchpoints

SECURITY MANAGEMENT	Risk register, remediation workflow, control ownership.
WORKFORCE / TERMINATION	Provisioning, deprovisioning, session revocation, group synchronization.
SECURITY AWARENESS	Phishing-resistant authentication, warning flows, safe defaults.
CONTINGENCY PLANNING	Backups, recovery, emergency-mode operation, data reconciliation.
WORKSTATION SECURITY	Session timeout, local-cache policy, download controls, screen exposure.

DEVICE / MEDIA

Encrypted storage, remote wipe where applicable, disposal and reuse processes.

PRINCIPLE

Architecture is socio-technical

If your application assumes “only trained users will do that,” the training is part of the control. If the consequence is serious, add technical prevention or detection rather than depending on memory alone.

MASTERY CHECK

- 01 Name one administrative safeguard that directly changes software behavior.

- 02 Why can a secure cloud backend still be undermined by workstation or download behavior?

Access Control and Emergency Access

LEARNING OBJECTIVE

Turn authorized access into explicit tenant-, facility-, role-, object-, and workflow-scoped decisions, including controlled emergency access.

Authentication answers who presented a credential. Authorization answers whether that principal may perform this action on this resource in this scope now. In a medical application, authorization usually combines identity, active membership, organization, facility, role/capability, object ownership, clinical/workflow state, and sometimes purpose.

- Request
- Identity validation
- Active organization membership
- Facility scope
- Role / capability
- Object belongs to allowed scope
- Workflow-state rule
- Action allowed
- Audit event

Emergency access / break-glass

Emergency access is not a backdoor account. Design it as a narrowly controlled capability: explicit invocation, strong authentication, limited scope, short duration, reason capture where appropriate, high-visibility audit, alerting, and post-event review. The exact implementation depends on operational needs and risk analysis.

LUMEN VASCULAR REPORTING PLATFORM

IMPLEMENTED

Tenant isolation in practice

A technologist at Facility A should not be able to fetch Facility B exams by changing an integer in the URL. In Lumen, every clinical endpoint requires authentication plus active organization membership, reads go through org-scoped selectors, and Postgres row-level security backs that up. A 24-case cross-tenant test matrix proves it. Break-glass is still *planned*: a support engineer should not become a hidden super-user merely because they can reach an admin console.

EXERCISE

Authorization matrix

For create exam, edit measurement, finalize, unfinalize, addendum, export PDF, retrieve image, view audit history, and emergency access, define who may act and under what organization/facility/workflow conditions.

Authentication, Sessions, and Identity Proof

LEARNING OBJECTIVE

Design authentication as a lifecycle: credential validation, session creation, refresh, revocation, replay resistance, reauthentication, and termination.

A valid JWT is evidence, not authorization. Authentication controls must also handle token lifetime, issuer/audience/signature validation, session state, stolen refresh tokens, logout, replay, password/MFA changes, account disablement, and compromised devices.

GAIT IDENTITY & SECURITY PLATFORM

Why session state matters

A robust hosted identity service can rotate refresh tokens, hash stored refresh credentials, detect replay across a token family, bind access tokens to server-side sessions, and revoke sessions after logout or compromise. The application consuming the token must still validate it and apply its own business authorization.

- Reject expired, wrong-issuer, wrong-audience, or invalid-signature tokens.
- Do not store raw refresh tokens server-side when a secure hash can be used for comparison.
- Serialize or otherwise control refresh behavior across browser tabs so rotation is not raced accidentally.

- Revoke server-side sessions after logout, replay, administrative disablement, or other security events.
- Require stronger or fresh authentication for especially sensitive actions when risk analysis supports it.

MASTERY CHECK

01 Why does a JWT not prove the user can open a particular exam?

02 What should happen to active sessions after refresh-token replay is detected?

Audit Controls: Security Telemetry vs ePHI Activity

LEARNING OBJECTIVE

Design audit mechanisms that can reconstruct ePHI activity without turning the logs into another uncontrolled copy of the medical record.

Section 164.312(b) requires mechanisms to record and examine activity in systems that contain or use ePHI. The common mistake is to point at a security-event pipeline and declare the requirement solved. Security telemetry and ePHI activity auditing answer different questions.

SECURITY EVENT LOG

“Was there an attack, anomaly, denial, rate-limit hit, CSRF failure?”

EPHI ACTIVITY LOG

“Who viewed/changed/exported which protected resource, when, in what scope, and with what outcome?”

These logs can share infrastructure, but the event catalog, coverage expectations, retention, review process, and access restrictions are different. An authorization-denied event is security telemetry. An authorized physician opening an exam may be ordinary ePHI activity that still matters for reconstruction.

Minimum useful audit fields

- Actor or authenticated subject reference.
- Organization/facility scope.

- Protected resource type and stable reference.
- Action: view, create, edit, finalize, export, send, retrieve media, etc.
- Timestamp and request/correlation identifier.
- Outcome and reason code.
- Session/context information appropriate to risk.
- Destination for disclosures/transmissions when applicable.

What not to log

- Raw JWTs or refresh tokens.
- Passwords or MFA secrets.
- Full report bodies merely to prove they were viewed.
- Long-lived signed URLs or credentials.
- Unnecessary patient names in free-form log messages.

A sample audit event

One structured event per protected action. It references the record; it does not copy it.

```
{
  "event_id": "01J9Z3K7N4Q8",           // unique, sortable
  "occurred_at": "2026-09-24T14:03:11.482Z",
  "category": "ephi_access",           // vs security | disclosure
  "action": "exam.view",
  "outcome": "allowed",                // allowed | denied | error
  "reason": null,                      // e.g. "not_org_member"
  "actor": { "subject": "usr_8f2c", "role": "physician",
             "session": "ses_41aa", "on_behalf_of": null },
  "scope": { "org": "org_12", "facility": "fac_3" },
  "resource": { "type": "exam", "id": "ex_9d01",
                "patient_ref": "pt_77b3" }, // internal id, not MRN
  "request": { "id": "req_c19e", "ip": "10.4.2.17",
               "endpoint": "GET /api/exams/{id}" },
  "destination": null                 // set for sends/exports
}
```

Two details carry weight. `patient_ref` lets an investigator or a privacy officer answer “who looked at this patient?” without the log holding the MRN or name. The endpoint template (`{id}`), not the literal URL) keeps identifiers in query strings out of the log.

Event-coverage matrix

Coverage is proven per path, not per service. Every PHI-bearing route gets a row and a test that asserts the event was written.

PATH	EVENT	CATEGORY	COVERAGE TEST
Worklist / exam list	exam.list	ePHI access	List call writes one event with result count, not row contents.
Exam detail	exam.view	ePHI access	Allowed and denied reads both write events.
Patient history	patient.history.view	ePHI access	Event carries <code>patient_ref</code> .
Sign / finalize / addendum	exam.finalize, ...	ePHI change	Written in the same transaction as the state change.
PDF export / download	report.export	ePHI access	Event records format and requester.
Media retrieve / presign	media.presign	ePHI access	Event written before the URL is returned.
HL7 result send	hl7.send	Disclosure	Event records destination and ACK outcome.
Patient export (Ch. 11)	patient.export	Disclosure	Event records purpose and recipient.
Support / break-glass	access.elevated	Security + access	Event records reason, approver, expiry; triggers alert.

TEST DESIGN

Make missing coverage fail the build

Keep a registry of PHI-bearing routes. A guardrail test enumerates the router, and any route not registered as audited — or explicitly exempted with a reason — fails CI. New endpoints then cannot ship silently unaudited.

A review procedure

Recording without examination satisfies half the standard. A minimal, workable review loop:

1. **Automated alerts (continuous):** denied-access bursts, cross-facility access attempts, break-glass use, bulk exports, access to records flagged as sensitive or belonging to workforce members.
2. **Weekly triage:** a named reviewer works the alert queue and records disposition: expected, explained, or escalated.
3. **Monthly sampling:** pick a small random set of patient records and check that every viewer had a plausible workflow reason.
4. **Quarterly evidence:** the coverage test report, reviewer sign-off, alert statistics, and any escalations filed with the control’s evidence packet (Chapter 20).

LUMEN VASCULAR REPORTING PLATFORM

PLANNED

The gap a good audit trail can hide

Lumen’s workflow history is append-only and has no update or delete path — for writes. Reads of exam detail, patient history, and preliminary reports write nothing today, so Lumen can answer “who changed this exam?” but not “who looked at this patient?” The coverage matrix above is Lumen’s build plan for closing that gap before real ePHI. A strong control in one direction is easy to mistake for coverage in both.

KEY DISTINCTION

Important legal distinction

Security audit controls support investigations and may support disclosure-accounting workflows where applicable, but §164.312(b) itself is not the same thing as the Privacy Rule’s accounting-of-disclosures right. Do not equate “every read” with a disclosure-accounting entry without analyzing the applicable rule.

RULE	§164.312(b) Audit controls
DEVELOPER QUESTION	Can we reconstruct meaningful activity in systems that contain/use ePHI?
ARCHITECTURE ANSWER	Central event catalog + durable audit store + protected access + review/alerting.
EVIDENCE	Coverage tests, sample events, retention config, access reviews, incident reconstruction exercises.

EXERCISE

Audit coverage map

List every PHI-bearing read/write/export/send path. Mark the event emitted, required fields, whether users can alter it, retention, and who reviews it.

Integrity and Clinical Meaning

LEARNING
OBJECTIVE

Protect ePHI from improper alteration or destruction and preserve the clinical meaning of the record across calculations, signing, correction, and transport.

Integrity is not merely “the database transaction committed.” In clinical software, the record can be technically consistent and still be clinically wrong: the wrong patient may be matched, the wrong criteria version may be applied, a finalized report may be silently overwritten, or an HL7 ORU may be routed to the wrong encounter.

Integrity controls by workflow stage

TEMPLATE → EXAM	Record template/protocol version and reproducibly create expected segments/measurements.
MEASUREMENTS → CALCS	Deterministic reviewed logic with threshold-boundary tests.
CONCLUSION	Provenance for rule version, human edits, and overrides.
FINALIZE / SIGN	Workflow lock, authorization, immutable event history, controlled addendum/correction.
HL7 / DICOM	Patient/order matching, message/study identifiers, destination binding, ACK/reconciliation.
STORAGE	Database constraints, backups, version history, checksums/signatures where risk analysis justifies them.

KEY DISTINCTION

Do not confuse these controls

Validation ≠ integrity proof. Transactionality ≠ auditability. Backup ≠ tamper detection. Authorization ≠ evidence that a record was unchanged.

EXERCISE

Wrong-patient scenario

A signed vascular report is correct in Lumen but arrives attached to the wrong patient in the EHR. Identify every possible boundary failure and the evidence needed to reconstruct the event.

Transmission Security and Encryption Decisions

LEARNING OBJECTIVE

Choose protection based on the real path, peer, network, data, and threat — not merely the protocol name.

The current Security Rule is technology-neutral. Encryption implementation specifications are addressable under the current rule, which means the organization must perform the required reasoned analysis. In modern internet/cloud designs, strong encryption in transit is ordinarily a baseline expectation, but the legal analysis and the architecture should still be documented rather than reduced to “TLS = compliant.”

Every connection record should answer

1. Source workload and owner.
2. Destination and owner.
3. Data classification.
4. Protocol and port.
5. Encryption or protected network.
6. Peer authentication.
7. Authorization and allowed direction.
8. Timeout/retry/replay behavior.
9. Monitoring/alerting.
10. Downtime and fail-safe behavior.

LAYERS

HL7 example

HL7 defines message structure. MLLP frames a message. TCP moves ordered bytes. None of those alone provides confidentiality, peer identity, or application authorization. Those protections come from the surrounding network and security architecture.

MASTERY CHECK

01 **Why is “MLLP over TCP” not a transmission-security answer?**

02 **What evidence would prove that an API path is protected in transit?**

Availability, Backups, and Downtime

LEARNING OBJECTIVE

Define recovery in measurable clinical terms and prove it with restoration and reconciliation exercises.

Availability means authorized users can obtain ePHI when needed. A backup is not a recovery capability until it has been restored successfully. Medical applications also need safe degraded behavior: what happens to studies in progress, queued HL7 results, signed reports, identity dependencies, and image retrieval when one component is unavailable?

Define the recovery contract

- **RPO:** how much data loss is tolerable?
- **RTO:** how long can the capability be unavailable?
- Restoration order and dependencies.
- Immutable/offline or otherwise resilient backup strategy appropriate to risk.
- Downtime workflow for clinicians and technologists.
- Queue preservation and idempotent replay.
- Validation after restoration.
- Reconciliation of work created during the outage.

EXERCISE • TABLETOP**Database outage tabletop**

At 10:15 a.m. the primary database is unavailable while two physicians are signing studies and 37 HL7 results are queued. Write the first five decisions, the degraded behavior, evidence preserved, recovery order, and reconciliation steps.

Documentation, Evidence, Retention, and Review

LEARNING
OBJECTIVE

Build a control evidence system so safeguards remain inspectable over time rather than existing only in developer memory.

The Security Rule includes policies/procedures and documentation requirements. Under §164.316(b)(2), required documentation must be retained for six years from the date of its creation or the date when it last was in effect, whichever is later. Developers should therefore design evidence as a durable artifact: risk decisions, control configurations, diagrams, access reviews, restore tests, incident records, and change history.

Three retention decisions, not one

“HIPAA says six years” is one of the most common misreadings in medical software. The six-year rule covers the Security and Privacy Rules’ required *documentation*. It does not set how long to keep medical records or every audit event.

WHAT	WHO SETS THE PERIOD	ENGINEERING IMPLICATION
Compliance documentation	HIPAA: six years from creation or last effective date.	Version policies, risk analyses, and evidence packets; never overwrite the prior version.

Clinical records	State law, payer and accreditation rules, the covered entity’s policy; often longer for minors.	Retention is a per-customer, per-record-type setting — and the BAA governs return or destruction at contract end.
Audit events	The organization’s policy, informed by risk analysis, investigation needs, and the six-year accounting lookback.	Tiered storage (hot for review, cold and immutable for history) with a documented, tested deletion job.

Evidence packet for a control

CONTROL	Cross-tenant authorization
OWNER	Application security / reports
DESIGN	Selector + permission + object ownership
CODE REFERENCE	Current repository path + commit
TESTS	Allowed + denied + ID-tampering + concurrency
RUNTIME EVIDENCE	Denied audit event samples
REVIEW	Date / reviewer / findings
RESIDUAL RISK	Documented
NEXT REVIEW	Date or trigger

PRINCIPLE

Evidence must age well

A screenshot of a green CI run is weak evidence if nobody can tell which commit, environment, configuration, or test suite it represents. Prefer traceable artifacts tied to version, owner, scope, and date.

Worked example: a completed control card

This is what a satisfactory answer to the exercise below looks like, using a real Lumen control.

CONTROL	Cross-tenant and cross-facility read isolation for exams
---------	--

RULE	§164.312(a)(1) Access control; §164.308(a)(4) Information access management
OWNER	Named engineer (reports service) · reviewer: named security lead
DESIGN	Authentication → active organization membership → org/facility-scoped selector → object lookup inside scope. Postgres row-level security as a second, independent layer.
CODE REFERENCE	Selector module, membership permission class, RLS migration – each cited by path and commit hash.
NEGATIVE TESTS	24-case adversarial matrix: wrong org, wrong facility, revoked membership, guessed IDs, list endpoints, write endpoints. Guardrail test fails the build if a new org-reachable table has no RLS decision.
RUNTIME EVIDENCE	CI run of the matrix tied to the release commit.
RESIDUAL RISK	Denied reads are not yet persisted as audit events (Chapter 16); a probing user would be blocked but not visible. Owner and target date recorded.
NEXT REVIEW	Quarterly, or on any new model, endpoint, or tenancy change.

Note what makes it satisfactory: specific enforcement points, a test that tries to break the control, evidence tied to a version, and an honest residual-risk line with an owner.

EXERCISE**Build a control card**

Choose one safeguard in your application and create an evidence packet with owner, design, implementation, tests, runtime evidence, residual risk, and review trigger.

PART

IV

Clinical systems and cloud boundaries

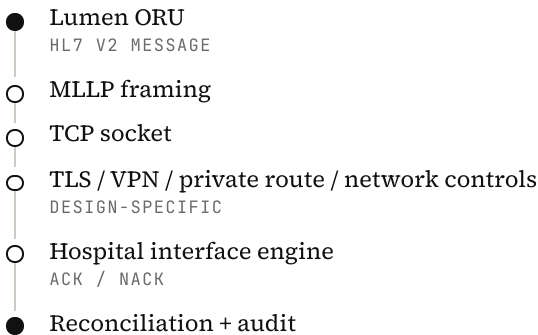
-
- 21 HL7, MLLP, TCP, and interface security
 - 22 DICOM and medical image security
 - 23 Cloud vendors, BAAs, secrets, and object storage
 - 24 Multi-tenancy, facilities, support access, and break-glass
-

HL7, MLLP, TCP, and Interface Security

LEARNING OBJECTIVE

Understand the transport stack well enough to secure clinical messaging and diagnose failures without confusing message semantics with network protection.

Think in layers. An HL7 v2 ORU message carries clinical meaning. MLLP adds delimiters so a receiver can find message boundaries on a byte stream. TCP gives reliable ordered delivery between sockets. The operating system's networking stack moves the bytes. Security must be intentionally added around this chain.



Interface controls that matter

- Fixed and verified destination; do not let untrusted client input choose the EHR endpoint.
- Network segmentation and allowlisting appropriate to the deployment.

- Protected transport and peer authentication appropriate to the route.
- Message control IDs and duplicate/replay strategy.
- ACK handling, timeout policy, retry limits, dead-letter/reconciliation workflow.
- Patient/order matching before and after transport.
- Audit events that do not dump entire messages into ordinary logs.

MASTERY CHECK

01 What security property does TCP provide that HL7 does not?

02 What does an ACK prove — and what does it not prove?

DICOM and Medical Image Security

LEARNING OBJECTIVE

Treat medical images and imaging metadata as first-class ePHI with controlled ingestion, storage, retrieval, sharing, and deletion.

DICOM is not “just image files.” Studies can contain patient identifiers in structured metadata, burned-in annotations, device information, dates, accession numbers, and other clinical context. Security must cover both pixel data and metadata.

Questions for every DICOM path

1. How is the sending node/workload identified?
2. How is the patient/study matched?
3. Is transport protected for DIMSE or DICOMweb?
4. Where are objects stored and encrypted?
5. Who may retrieve a study and how is tenant/facility scope enforced?
6. How are presigned URLs scoped and expired?
7. Are retrievals audited?
8. How are thumbnails, caches, temp files, exports, and local downloads handled?

LUMEN VASCULAR REPORTING PLATFORM

ILLUSTRATIVE

Media-service boundary

Authorization must happen before issuing a signed object-storage URL. Object-key secrecy is not authorization. A guessed key must still fail because the application verifies organization, facility, resource ownership, and actor permission before presigning.

EXERCISE

Trace one image

Trace a DICOM object from scanner/import through media service, object storage, browser retrieval, cache, and deletion. Mark every copy and temporary representation.

Cloud Vendors, BAAs, Secrets, and Object Storage

LEARNING OBJECTIVE

Evaluate each dependency as part of the regulated system and keep contractual scope aligned with actual technical data flow.

A cloud provider's HIPAA program does not transfer compliance to your application. Determine which services are covered by contractual assurances, which resources actually receive ePHI, how identities and keys are managed, and how data is retained, backed up, logged, and deleted.

Vendor inventory fields

FIELD	YOUR ENTRY
Vendor / service	
Purpose	
Data received or maintained	
PHI / ePHI?	
BAA / contract status	
Regions / services in scope	
Encryption / key ownership	
Retention / deletion	
Subprocessors	
Security evidence owner	

Secrets

Secrets should not live in source code, client bundles, ordinary logs, support tickets, or screenshots. Centralize secret management, minimize scope, rotate when compromise or policy requires, and design services so one credential does not grant unrestricted access across tenants or environments.

PATTERN

Object storage

Keep buckets private by default. Authorize at the application boundary before issuing short-lived access. Bind object keys to server-side resource truth. Audit grants and retrieves appropriate to risk. Test cross-tenant key substitution.

MASTERY CHECK

01 Why is “the vendor signs a BAA” not sufficient technical evidence?

02 What is the security difference between a private bucket and authorized object access?

Multi-tenancy, Facilities, Support Access, and Break-Glass

LEARNING
OBJECTIVE

Prevent one customer, facility, support user, or automation path from becoming a hidden cross-tenant authorization bypass.

Multi-tenant medical software adds a second axis beyond ordinary role-based access: every read and write must be scoped to the correct tenant, and often a facility. The most dangerous bugs occur when one endpoint applies tenant scope while another uses an unscoped primary-key lookup.

Layered pattern

MODELS	Store organization ownership and integrity constraints.
SELECTORS	Apply organization/facility filters to reads.
SERVICES	Enforce authorized writes and workflow invariants.
PERMISSIONS	Reject unauthorized actions before protected logic runs.
SERIALIZERS	Expose only approved fields.
VIEWS	Orchestrate but never trust client-supplied tenant truth.
TESTS	Attempt horizontal and vertical privilege escalation.

Support access

Support impersonation is high risk because it can bypass normal accountability. Prefer diagnostic tooling that exposes necessary technical state without becoming the user. If impersonation or break-glass access is truly needed, constrain it with approval, visibility, expiry, scope, strong audit, and post-use review.

EXERCISE

IDOR hunt

List every endpoint that accepts an exam ID, report ID, media ID, facility ID, or organization slug. For each, identify where server-side ownership is verified and write the cross-tenant negative test.

PART

V

Secure software engineering

-
- 25 OWASP Top 10:2025 for medical applications
 - 26 OWASP ASVS 5.0 as a verification backbone
 - 27 Threat modeling and secure design
 - 28 Secure development lifecycle and supply-chain assurance
 - 29 Testing controls, exceptional conditions, and fail-safe behavior
 - 30 Incident response, breach readiness, and evidence preservation
-

OWASP Top 10:2025 for Medical Applications

LEARNING
OBJECTIVE

Use the OWASP Top 10 as a risk-awareness map while recognizing that it is not a complete application-security verification standard.

OWASP Top 10:2025 is an awareness document for critical web-application risks. The 2025 list is: Broken Access Control; Security Misconfiguration; Software Supply Chain Failures; Cryptographic Failures; Injection; Insecure Design; Authentication Failures; Software or Data Integrity Failures; Security Logging and Alerting Failures; and Mishandling of Exceptional Conditions. OWASP explicitly recommends ASVS when you need a verifiable security standard rather than a Top 10 awareness list.

2025 CATEGORY	MEDICAL APPLICATION FAILURE EXAMPLE
A01 Broken Access Control	Tenant/facility/object bypass, IDOR, role escalation, support backdoors.
A02 Security Misconfiguration	Debug mode, permissive CORS, public buckets, weak headers, default credentials, unsafe cloud/IAM settings.
A03 Software Supply Chain Failures	Compromised dependencies, build systems, CI actions, registries, package confusion, unverified artifacts.
A04 Cryptographic Failures	Cleartext PHI, poor key handling, obsolete protocols, incorrect certificate verification.

A05 Injection	SQL/command/template/LDAP/XSS and parser injection across APIs, search, HL7, files, admin tooling.
A06 Insecure Design	Missing threat model, unsafe workflow assumptions, no abuse cases, no trust-boundary design.
A07 Authentication Failures	Weak session lifecycle, token replay, broken MFA/reset, account enumeration.
A08 Software or Data Integrity Failures	Untrusted updates/artifacts, unsigned data/code paths, unsafe deserialization, broken provenance.
A09 Security Logging and Alerting Failures	No audit coverage, no alerts, noisy logs, secrets/PHI in logs, no review.
A10 Mishandling of Exceptional Conditions	Fail-open auth, swallowed errors, unsafe retries, inconsistent partial state, resource exhaustion.

PRINCIPLE

HIPAA + OWASP

HIPAA asks what safeguards a regulated health-information system must have. OWASP asks how modern applications commonly fail. A secure medical application needs both legal/regulatory analysis and rigorous application-security engineering.

EXERCISE**Top 10 mapping**

For each OWASP 2025 category, identify one control in your application and one missing negative test or evidence artifact.

OWASP ASVS 5.0 as a Verification Backbone

LEARNING OBJECTIVE

Use ASVS 5.0 to turn broad security intentions into testable application-security requirements.

OWASP ASVS 5.0 is a better backbone for verification than claiming “OWASP Top 10 compliance.” OWASP describes ASVS as a basis for testing application technical security controls and the technical controls the application relies upon. Use it to define what must be verified, then map relevant requirements to HIPAA risks and your architecture.

A practical mapping approach

1. Choose the assurance level appropriate to the application’s sensitivity and risk. Medical applications often justify a stronger verification posture than ordinary low-risk sites.
2. Select ASVS requirements relevant to your architecture and deployment.
3. Map each requirement to a code/configuration enforcement point.
4. Add automated tests where possible and manual verification where necessary.
5. Retain evidence with version, environment, owner, and date.
6. Reassess after material architecture, identity, integration, or vendor changes.

CAUTION

Do not market a checklist as proof

OWASP itself discourages claims of complete Top 10 coverage. A mature statement is narrower: “Our secure development and verification program uses OWASP Top 10:2025 for risk awareness and ASVS 5.0 as a verification reference,” followed by evidence.

EXERCISE

Build an ASVS control map

Choose 15 ASVS requirements relevant to authentication, authorization, sessions, data protection, logging, APIs, configuration, and secure communication. Map each to implementation and test evidence.

Threat Modeling and Secure Design

LEARNING
OBJECTIVE

Find architectural security failures before they become code by modeling assets, trust boundaries, attackers, abuse cases, and safety consequences.

Insecure design cannot be patched away with input validation. Threat modeling asks what the system is, where trust changes, which assets matter, who may attack or misuse it, and what controls should exist before implementation.

Threat-model one feature before coding

ASSET	What PHI, capability, or clinical decision needs protection?
ACTORS	Patient, clinician, technologist, admin, support, attacker, service account, vendor.
TRUST BOUNDARIES	Browser/API, API/database, service-to-service, cloud/vendor, hospital network, AI provider.
ABUSE CASES	ID tampering, replay, role escalation, wrong-patient mapping, mass export, poisoned input, denial of service.
SAFETY BEHAVIOR	What happens when the dependency is wrong, slow, unavailable, or malicious?
EVIDENCE	Which test proves the design assumption?

PRINCIPLE

Medical design includes clinical misuse

A system can be secure from attackers and still be unsafe if the wrong patient is selected, a stale criteria version drives a conclusion, or a retry sends duplicate results. Treat clinical workflow invariants as security-relevant design constraints.

EXERCISE

Threat-model media presign

Threat-model the path from browser request to authorization to object-storage signed URL. Include cross-tenant guessing, URL leakage, expired credentials, support access, logs, and replay.

Secure Development Lifecycle and Supply-Chain Assurance

LEARNING OBJECTIVE

Embed security into design, coding, review, dependency management, CI/CD, deployment, and maintenance.

Secure development is a lifecycle, not a final penetration test. The 2025 OWASP list makes software supply-chain failures a first-class category because modern applications trust package registries, CI actions, build images, lockfiles, artifact stores, deployment tokens, and third-party code.

Engineering habits by phase

DESIGN	Data classification, threat model, trust-boundary diagram, privacy purpose/minimum necessary.
BUILD	Centralized authorization, safe parsing, parameterized queries, secret management, secure defaults.
REVIEW	Security-context code review, dependency changes, config/IAM changes, schema/data-flow changes.
TEST	Positive/negative auth, concurrency, fuzzing where useful, integration failure, recovery, log redaction.
CI	Pinned/controlled dependencies and actions, SCA, secret scanning, test gates, artifact integrity.
DEPLOY	Least-privilege deployment identities, immutable artifacts, approvals, rollback, environment separation.

OPERATE	Patching, vulnerability triage, alerts, incident response, restore drills, periodic access and risk review.
---------	---

GAIT IDENTITY & SECURITY PLATFORM

Intelligence does not grant authority

An AI agent can investigate, propose, or validate, but consequential deployment or security actions must remain constrained by deterministic policy, capability boundaries, immutable artifacts, and human approval where required.

MASTERY CHECK

- 01 Why can a clean source repository still produce a compromised deployment?
- _____
- _____
- _____
- _____
- 02 What supply-chain evidence would you retain for a production release?
- _____
- _____
- _____
- _____

Testing Controls, Exceptional Conditions, and Fail-Safe Behavior

LEARNING OBJECTIVE

Prove controls under allowed, denied, concurrent, partial-failure, timeout, retry, and dependency-outage conditions.

Happy-path tests prove functionality. Security tests prove boundaries. The 2025 OWASP A10 category is a useful reminder that systems often fail during abnormal conditions: a timeout skips an authorization check, a retry duplicates a clinical message, an exception returns raw PHI, or a downstream outage leaves a workflow in an unsafe intermediate state.

A security test matrix

DIMENSION	CASES TO COVER
Scope	Allowed actor / allowed resource · Allowed actor / wrong tenant · Allowed actor / wrong facility · Wrong role / correct object
Session & concurrency	Expired/revoked session · Concurrent single-use action
Uncertain outcomes	Dependency timeout before commit · Dependency timeout after commit · Retry after uncertain outcome · Malformed clinical payload
Dependency outages	Logging path fails · Audit store unavailable · Object store unavailable · Identity provider unavailable · HL7 receiver returns NACK or never ACKs

PRINCIPLE

Fail closed is not universally “stop everything”

In healthcare, availability and patient safety matter. The design question is safe failure: which actions must deny, which can continue in degraded mode, how data is queued, what is visible to users, and how reconciliation occurs afterward.

EXERCISE

Break the workflow

Choose report finalization or HL7 send. Write tests for timeout before commit, timeout after commit, duplicate retry, audit-write failure, permission change mid-request, and downstream NACK.

Incident Response, Breach Readiness, and Evidence Preservation

LEARNING OBJECTIVE

Design the product so responders can contain, investigate, recover, and provide reliable facts for privacy/legal assessment.

An incident is an operational event requiring response. A breach is a legal determination under the HIPAA Breach Notification Rule. Developers should preserve trustworthy facts rather than making that legal conclusion alone.

First-hour engineering responsibilities

1. Contain the vulnerable capability without destroying evidence.
2. Preserve relevant logs, deployments, database state, identity/session evidence, and configuration.
3. Determine earliest plausible exposure and affected resources/tenants.
4. Revoke or rotate compromised credentials and sessions when appropriate.
5. Coordinate with privacy/security/legal leadership according to the incident plan.
6. Repair the central control, not merely the single observed URL.
7. Add regression tests and reassess similar paths.

From incident to breach determination

The first hour stabilizes the system. The next steps decide whether the law requires notification, and the clock may already be running.

- **Discovery**
CLOCK STARTS
- **Contain + preserve evidence**
- **Was PHI involved? Was it unsecured?**
IF NOT UNSECURED → NO BREACH NOTIFICATION
- **Does an exception apply?**
- **Four-factor risk assessment**
PRIVACY OFFICER / COUNSEL DECIDE
- **Notify or document why not**

DISCOVERY

A breach is treated as discovered on the first day it is known — or, by exercising reasonable diligence, would have been known — to any workforce member or agent other than the person who committed it. “We didn’t read the alert” does not stop the clock.

UNSECURED PHI

PHI not rendered unusable, unreadable, or indecipherable to unauthorized persons under HHS guidance — in practice, encryption consistent with that guidance with keys not compromised, or proper destruction. This is why key management evidence matters during an incident.

EXCEPTIONS

Narrow: unintentional, good-faith access by a workforce member acting within scope; inadvertent disclosure between people authorized at the same organization or arrangement; a good-faith belief the recipient could not have retained the information.

RISK ASSESSMENT

An impermissible use or disclosure is presumed to be a breach unless a documented assessment shows a low probability of compromise, considering: (1) the nature and extent of the PHI, including identifiers and re-identification likelihood; (2) who received or used it; (3) whether it was actually acquired or viewed; (4) the extent the risk was mitigated.

WHO DECIDES	The covered entity’s privacy officer and counsel, following the incident plan. Engineering supplies the facts behind every factor — especially factor 3, which only your audit logs can answer.
-------------	---

Deadlines

NOTICE	DEADLINE
Business associate → covered entity (§164.410)	Without unreasonable delay, and no later than 60 calendar days after discovery. Include the identity of each affected individual as available. BAAs often require much faster notice — sometimes days — so the contract, not the regulation, usually sets your real clock.
Covered entity → individuals (§164.404)	Without unreasonable delay, and no later than 60 calendar days after discovery.
Media (§164.406)	When more than 500 residents of a state or jurisdiction are affected; same 60-day limit.
HHS (§164.408)	500 or more individuals: contemporaneously with individual notice. Fewer than 500: log and report within 60 days after the end of the calendar year.
State law	Often separate triggers and shorter deadlines. Check every state where affected individuals live.

PRINCIPLE

60 days is a ceiling, not a target

The standard is “without unreasonable delay.” Holding a notice until day 59 when the facts were ready on day 10 can itself be a violation. The burden of proving that notice was timely, or that no breach occurred, sits with the covered entity or business associate — which is why the risk assessment must be written down.

What engineering must be able to answer fast

- Exactly which records, patients, and tenants were exposed — from audit data, not estimates.

- Whether exposed data was encrypted at rest and in transit, and whether keys were exposed.
- Whether the data was actually viewed or downloaded, not merely reachable.
- The earliest plausible exposure date, backed by deployment history.
- Contact data for affected individuals, sourced through the covered entity.

LUMEN VASCULAR REPORTING PLATFORM

ILLUSTRATIVE

Tabletop scenario

Suppose a technologist changes an exam ID and sees another organization's exam. Treat it as a possible systemic object-authorization failure until proven otherwise. Search all resource lookup paths that use the same pattern; do not patch only the reported endpoint.

EXERCISE • TABLETOP

Cross-tenant first hour

Write the first-hour response to a report that one user viewed another organization's exam. Include containment, evidence, scope questions, credential actions, communication, remediation, and verification.

PART

VI

Capstone

Perform a HIPAA Engineering Review of Lumen — Then Your Own System

LEARNING OBJECTIVE

Produce a complete, evidence-driven architecture review that integrates privacy, HIPAA safeguards, clinical workflow, OWASP risks, verification, vendors, and recovery.

STEP 1 **System statement**

In 200 words, describe the product, users, regulated customers, PHI/ePHI, integrations, deployment, vendors, and trust boundaries. If you cannot state the system clearly, you cannot analyze it clearly. Then label each capability implemented, partial, planned, or illustrative, as the introduction does for Lumen. Reviewers trust a system statement that admits its gaps.

STEP 2 **Data inventory and purpose**

DATA	PHI / EPHI?	PURPOSE	SYSTEM OF RECORD	COPIES / DESTINATIONS	RETENTION OWNER
Signed vascular report EXAMPLE	ePHI; in the DRS	Treatment	Reports DB	PDF in object store; EHR via HL7 (planned); backups	Covered entity policy; Lumen per BAA

STEP 3 **Trust-boundary map**

Draw every browser, API, service, database, object store, cache, queue, identity provider, observability provider, developer/support surface, AI provider, backup, EHR/interface engine, DICOM node, export, and temporary file location. Mark each arrow with data type, protocol, authentication, authorization, and transport protection.

STEP 4 **HIPAA safeguard map**

For every applicable safeguard, complete:

RULE → DEVELOPER QUESTION → ARCHITECTURE → CODE/CONFIG ENFORCEMENT →
NEGATIVE TEST → EVIDENCE → GAP → OWNER → REVIEW DATE

A completed row, so you know the level of detail to aim for:

RULE	§164.312(e)(1) Transmission security
QUESTION	Can anyone on the network path read or forge the HL7 orders Lumen receives?
ARCHITECTURE	MLLP listener bound to one organization at startup; organization never taken from message content.
ENFORCEMENT	Listener startup configuration; no transport encryption yet.
NEGATIVE TEST	A message claiming another organization is filed under the bound organization only — passes. A plaintext capture on the path reveals PHI — fails.
EVIDENCE	Tenant-binding test; packet capture from the test environment.
GAP	No TLS/MLLPS or VPN, no sender authentication. Blocks real ePHI.

OWNER / REVIEW	Named integration engineer · before first hospital connection

STEP 5 **Privacy engineering**

- Identify where minimum necessary is enforced in query/selector and response contracts.
- Identify any de-identification boundary and the regulatory method used.
- Identify limited data sets and DUAs, if any.
- Identify every AI/analytics/research outbound path and its legal/contractual basis.
- Show the patient export and amendment path, and where accountable disclosures are logged (Chapter 11).
- Identify any special data classes (Part 2, psychotherapy notes, state-protected categories) and who reviewed them.

STEP 6 **OWASP / ASVS verification**

Map OWASP Top 10:2025 risks to the application. Use ASVS 5.0 requirements as the verifiable control baseline appropriate to the application. Record evidence, gaps, and exceptions.

STEP 7 **Recovery and incident proof**

- Perform a restore test.
- Run an identity-provider outage tabletop.
- Run an HL7 receiver outage/retry exercise.

- Run a cross-tenant access incident tabletop.
- Verify audit coverage and log redaction.

STEP 8 **Go-live evidence packet**

- ☐ Current system/data-flow diagrams.

- ☐ Risk analysis and treatment plan.

- ☐ Privacy/minimum-necessary/de-identification decisions.

- ☐ Authorization matrix and tenant-isolation tests.

- ☐ Authentication/session lifecycle evidence.

- ☐ Audit event catalog and coverage tests.

- ☐ Integrity/workflow-state tests.

- ☐ Encryption/network/interface records.

- ☐ Backup restore and downtime exercises.

- ☐ Vendor inventory and agreements, including the customer BAA and every subcontractor BAA.

- ☐ Patient access, amendment, and disclosure-accounting capability, tested.

- ☐ Breach-notification path with the contractual notice deadline and named decision-makers.

- ☐ OWASP/ASVS verification results.

- ☐ Incident response plan and exercise records.

- ☐ Deployment, rollback, and supply-chain evidence.

- ☐ Named owners and review dates.
-

THE STANDARD YOU SHOULD AIM FOR

You can point to any important claim — *“only this facility can read this study,” “the report cannot be silently changed after signing,” “this dataset is Safe Harbor de-identified,” “this HL7 destination is fixed,” “we can restore within our RTO”* — and show the architecture, code/configuration, negative test, and evidence that support it.

Quick Reference: HIPAA Developer Questions

AREA	QUESTION
Scope	What PHI/ePHI exists? Why is it in scope? Which entity/BA relationship creates the obligation?
Purpose	Why is the data used/disclosed? Does minimum necessary apply?
Identity	How is the actor authenticated and how is session state revoked?
Authorization	How are tenant, facility, role, object, workflow state, and emergency access enforced?
Audit	Can we reconstruct access, changes, exports, sends, denials, and security events without logging excess PHI?
Integrity	How do we detect/prevent improper alteration or destruction and preserve clinical provenance?
Transmission	How are peers identified and ePHI protected across every network boundary?
Availability	What are RPO/RTO, downtime behavior, restoration order, and reconciliation?
Vendors	Which vendors can receive/maintain ePHI and what contractual/service scope applies?
Patient rights	Can we find, export, and amend one patient's designated record set, and list accountable disclosures?
Special data	Could this workflow touch Part 2, psychotherapy notes, or state-protected data? Who reviewed it?

Breach Who decides, what is our contractual notice clock, and can audit data show what was actually viewed?

AI Is the input PHI, limited data set, or de-identified? What happens to prompts/outputs/telemetry?

Evidence What test, config, review, event, or exercise proves the control works?

OWASP Top 10:2025 Checklist

- ☐ **A01 Broken Access Control**
Tenant/facility/object bypass, IDOR, role escalation, support backdoors.

CONTROL / EVIDENCE _____
- ☐ **A02 Security Misconfiguration**
Debug mode, permissive CORS, public buckets, weak headers, default credentials, unsafe cloud/IAM settings.

CONTROL / EVIDENCE _____
- ☐ **A03 Software Supply Chain Failures**
Compromised dependencies, build systems, CI actions, registries, package confusion, unverified artifacts.

CONTROL / EVIDENCE _____
- ☐ **A04 Cryptographic Failures**
Cleartext PHI, poor key handling, obsolete protocols, incorrect certificate verification.

CONTROL / EVIDENCE _____
- ☐ **A05 Injection**
SQL/command/template/LDAP/XSS and parser injection across APIs, search, HL7, files, admin tooling.

CONTROL / EVIDENCE _____
- ☐ **A06 Insecure Design**
Missing threat model, unsafe workflow assumptions, no abuse cases, no trust-boundary design.

CONTROL / EVIDENCE _____

- ☐ **A07 Authentication Failures**
Weak session lifecycle, token replay, broken MFA/reset, account enumeration.

CONTROL / EVIDENCE _____
- ☐ **A08 Software or Data Integrity Failures**
Untrusted updates/artifacts, unsigned data/code paths, unsafe deserialization, broken provenance.

CONTROL / EVIDENCE _____
- ☐ **A09 Security Logging and Alerting Failures**
No audit coverage, no alerts, noisy logs, secrets/PHI in logs, no review.

CONTROL / EVIDENCE _____
- ☐ **A10 Mishandling of Exceptional Conditions**
Fail-open auth, swallowed errors, unsafe retries, inconsistent partial state, resource exhaustion.

CONTROL / EVIDENCE _____

Vocabulary for Medical Application Developers

BAA	Business Associate Agreement.
CE	Covered Entity.
PHI	Protected Health Information.
ePHI	Electronic Protected Health Information.
DUA	Data Use Agreement used with a limited data set under the applicable Privacy Rule provisions.
DRS	Designated record set: records used, in whole or in part, to make decisions about individuals; the scope of the right of access.
Part 2	42 CFR Part 2: federal confidentiality rules for certain substance use disorder treatment records.
Unsecured PHI	PHI not rendered unusable, unreadable, or indecipherable to unauthorized persons under HHS guidance; the trigger for breach notification.
Discovery	The day a breach is known, or with reasonable diligence would have been known; notification clocks start here.
OCR	HHS Office for Civil Rights, which administers and enforces HIPAA privacy/security rules.
RPO	Recovery Point Objective: tolerated data-loss window.
RT0	Recovery Time Objective: target time to restore a capability.

HL7 v2	Clinical messaging standard commonly used for ADT, orders, results, and other interfaces.
MLLP	Minimal Lower Layer Protocol, a framing convention commonly used to carry HL7 v2 messages over a stream such as TCP.
TCP	Transport protocol providing reliable ordered byte delivery between endpoints.
ACK/NACK	Acknowledgment / negative acknowledgment used in message-processing workflows.
DICOM	Standard for medical imaging information and communication.
JWT	JSON Web Token; a token format, not an authorization system by itself.
IDOR/BOLA	Object-authorization weakness where changing an identifier can expose another resource.
ASVS	OWASP Application Security Verification Standard.
SCA	Software Composition Analysis for dependency risk.
SBOM	Software Bill of Materials: inventory of software components.

Stack Translation: Django, FastAPI, Next.js, Convex, Clerk

The controls in this book do not change with the framework. Where they are enforced, and how each stack can quietly bypass them, does. Vendor capabilities and contract terms change; confirm every BAA and plan detail with the vendor at the time you build.

CONTROL	DJANGO / DRF	FASTAPI	NEXT.JS	CONVEX
Authenticate	Auth class in default settings	Router-level dependency	Verify in data layer, not only middleware	ctx.auth in every public function
Tenant scope	Scoped selectors + RLS	Org-context dependency + scoped repository	Delegated to the backend	Index by org + membership check
Field projection	Explicit serializer fields	response_model	DTOs to client components	Return mapped objects
Read audit	View or selector hook	Dependency or route wrapper	The backend's job	Mutation or log stream (queries cannot write)

Clerk (identity)

- **Verify on the server, every request:** signature, expiry, issuer, and authorized parties. A token that parses is not a token that verifies.
- **Organization claims are a starting point:** the active-organization claim says which tenant the user selected. Your data layer must still check

- object ownership, and signed claims can lag a revoked role until the token refreshes. Keep session tokens short-lived and test revocation.
- **Metadata is not a place for PHI or authority:** user-writable (“unsafe”) metadata must never drive authorization, and public metadata is readable in the browser. Keep clinical data out of identity metadata altogether.
- **Is the identity provider inside the BAA perimeter?** For a clinician-only product, workforce accounts are usually not PHI. For a patient-facing product, the account itself can be PHI — being a patient of a given clinic is health information. Confirm directly with Clerk whether a BAA is available for your plan before patient identities go there; if not, keep patient identity elsewhere.
- **Webhooks:** verify signatures before trusting the user and membership events that drive deprovisioning.

Convex (backend and database)

- **Every public function is an endpoint:** any client with the deployment URL can call a public query, mutation, or action. Authenticate and authorize inside each one; use internal functions for anything only the server should run.
- **Validate arguments** on every public function. An ID argument is a claim to check against the caller’s organization, not a lookup key to trust.
- **Queries are read-only.** They cannot write an audit row, so a query that returns PHI leaves no record of its own. Either serve sensitive detail through a mutation that records the access and then returns the projection (losing reactivity for that view), or use exported function logs as the access record after confirming they carry actor and resource. Decide deliberately; do not discover this in an audit.
- **Subscriptions keep data flowing:** test that removing a membership stops updates reaching an already-open client.
- **Logs and dashboards:** `console.log` output and function arguments land in logs your team can read. Keep PHI out of both.

- **File URLs are bearer credentials:** generate them only after authorization, and know their lifetime.
- **BAA:** Convex states that HIPAA-regulated businesses may process PHI after signing its BAA. Confirm plan eligibility and which features the agreement covers.

FastAPI (services)

- **Attach authentication and organization context at the router** (`dependencies=[ ... ]`) so new routes inherit it instead of opting in.
- **Always declare `response_model`.** Returning an ORM object without one sends every attribute it serializes.
- **Validation errors echo input:** the default 422 response includes the offending value, which may be PHI and may be logged downstream. Customize the handler to return field names, not values.
- **Access logs record URLs:** keep MRNs, names, and dates out of paths and query strings.
- **Background tasks run after the response** and fail quietly. Required audit writes belong in the request path.

Next.js and React (frontend)

- **Server Actions are public POST endpoints.** Authenticate and authorize inside every action; a protected page does not protect the action it calls.
- **Middleware is not your authorization layer.** A 2025 vulnerability (CVE-2025-29927) let crafted requests skip Next.js middleware entirely. Check access in a server-side data layer close to the query.
- **Props to client components are sent to the browser.** Passing a full patient object to a client component discloses every field. Pass purpose-built DTOs.
- **Caching can cross users:** render PHI pages dynamically, send `Cache-Control: private, no-store`, and verify the CDN honors it.
- **NEXT_PUBLIC_ variables are bundled into client code.** Never put secrets there.

- **The browser is a disclosure surface:** no PHI in localStorage, URLs, page titles, or analytics events. Session replay, analytics pixels, and error monitoring that capture page content are vendors receiving PHI — mask them, remove them from authenticated pages, or bring them inside the BAA perimeter. HHS has issued guidance on online tracking technologies; parts were vacated by a federal court in 2024, but tracking on authenticated patient pages remains a clear risk.
- **Hosting and edge providers** that serve PHI-bearing responses are part of the regulated data flow.

Django and DRF (this book's default)

- Set authentication and permission defaults in settings so a view that forgets them fails closed.
- Serializers list fields explicitly; never `fields = "__all__"` on a PHI model.
- Object lookups run against the scoped queryset, so a guessed ID returns 404, not someone else's record.
- `DEBUG = False` in every non-local environment; debug pages print local variables, which can include PHI.

Reference Map

Validate production decisions against current primary sources. The references below were used to shape this September 2026 edition.

HHS **The Security Rule**

hhs.gov/hipaa/for-professionals/security/index.html

HHS **Summary of the HIPAA Security Rule**

hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html

ECFR **45 CFR Part 164**

ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164

HHS **Summary of the HIPAA Privacy Rule**

hhs.gov/hipaa/for-professionals/privacy/laws-regulations/index.html

HHS **Minimum Necessary Requirement**

hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html

HHS **De-identification Guidance**

hhs.gov/hipaa/for-professionals/special-topics/de-identification/index.html

HHS **Limited Data Set / Research guidance**

hhs.gov/hipaa/for-professionals/privacy/guidance/research/index.html

HHS **Breach Notification Rule**

hhs.gov/hipaa/for-professionals/breach-notification/index.html

HHS **Individuals' Right of Access**

hhs.gov/hipaa/for-professionals/privacy/guidance/access/index.html

HHS **42 CFR Part 2 final rule fact sheet**

hhs.gov/hipaa/for-professionals/regulatory-initiatives/fact-sheet-42-cfr-part-2-final-rule/index.html

HHS **Sample business associate agreement provisions**

hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html

HHS **Security Rule NPRM**

hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/index.html

OWASP **Top 10:2025**

top10.owasp.org/2025/

OWASP **Application Security Verification Standard 5.0**

owasp.org/projects/asvs

OWASP **Web Security Testing Guide**

wstg.owasp.org

REGULATORY FRESHNESS

This book deliberately distinguishes the Security Rule currently in effect from HHS's proposed cybersecurity modifications. Re-check HHS/OCR and eCFR for final-rule changes before relying on a specific implementation specification.

Final Self-Assessment

I CAN NOW...	NOT YET	WITH HELP	INDEPENDENTLY
Explain covered entity vs business associate and draw the BAA perimeter.	☐	☐	☐
Classify PHI/ePHI and explain why context and linkage matter.	☐	☐	☐
Name the minimum-necessary exceptions and still design minimal APIs.	☐	☐	☐
Support access, amendment, and accounting requests for records my system holds.	☐	☐	☐
Design minimum-necessary APIs and query projections.	☐	☐	☐
Explain Safe Harbor, Expert Determination, and Limited Data Sets.	☐	☐	☐
Review AI/model data flows for PHI, contracts, minimization, retention, and logging.	☐	☐	☐
Map a complete clinical data flow and trust boundaries.	☐	☐	☐
Write a useful HIPAA risk scenario and treatment plan.	☐	☐	☐
Review tenant/facility authorization and emergency access.	☐	☐	☐
Design audit events without copying excessive PHI into logs.	☐	☐	☐

Explain clinical integrity controls for signing, addenda, HL7, and DICOM.	☐	☐	☐
Explain HL7 + MLLP + TCP + transport protection.	☐	☐	☐
Define RPO/RTO and prove restoration/reconciliation.	☐	☐	☐
Map OWASP Top 10:2025 and use ASVS 5.0 as a verification reference.	☐	☐	☐
Walk an incident to a breach determination and name every notice deadline.	☐	☐	☐
Run a cross-tenant incident tabletop and preserve evidence.	☐	☐	☐
Assemble evidence instead of merely claiming compliance.	☐	☐	☐

Written by Anthony Narine — software engineer with 17 years in vascular ultrasound. Lumen, Gait, and EstateIQ can be explored at anthonymnarine.com. Set in Fraunces, Source Serif 4, and JetBrains Mono.